

Encryption Policy

Cryptographic standards for data at rest and in transit (PR.DS)

Document ID: BVT-POL-035

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose, Scope, and Authority

This policy is part of the BVTech Written Information Security Program, aligned to the NIST Cybersecurity Framework (CSF) 2.0. It applies to all BVTech LLC personnel, contractors, systems, and, where adopted by a client, the client's covered environment. The Managing Partner (or designated security officer) owns this policy, reviews it at least annually, and approves exceptions in writing. Violations may result in disciplinary action up to termination of employment or contract.

Exception process: submit written request describing the business need, compensating controls, and duration. Exceptions expire after 12 months unless renewed. NIST CSF 2.0 references shown per section (GV, ID, PR, DE, RS, RC).

Required Standards

- In transit: TLS 1.2+ (TLS 1.3 preferred) for all services; SSH v2 for administration; VPN with modern ciphers (WireGuard, IKEv2/AES-256, or OpenVPN AES-256-GCM). Legacy protocols (SSLv3, TLS 1.0/1.1, SMBv1, unencrypted FTP/Telnet) are prohibited.
- At rest: full-disk encryption on all laptops and workstations (BitLocker/FileVault) and on servers holding Restricted or Confidential data; AES-256 for backup encryption (iDrive private key encryption enabled).
- Email: enforced TLS for mail transport; sensitive attachments shared via secure links, not attachments, where possible.
- Removable media: prohibited for Restricted data; encrypted and approved case-by-case otherwise.

Key Management

- Recovery keys (BitLocker, backup private keys) are escrowed in the credential vault under Restricted classification — losing a backup private key means unrecoverable data.
- Keys are generated on trusted systems, never emailed in plaintext, rotated upon suspected compromise, and access-logged.
- Certificates: tracked with expiration alerts at 30 days; private keys are non-exportable where the platform allows.

Verification

Disk-encryption status is monitored via RMM and reported in client baseline and QBR reporting. Unencrypted devices holding covered data are remediated within five (5) business days or removed from service.